

Detailed Design

Design Principles

- Tenant context is resolved once during authentication and passed through request handling.
- Workflow side effects are asynchronous where possible.
- Message processing is idempotent because Service Bus delivery is at least once.
- Admin impersonation is always audited and never grants the impersonated user admin rights.
- Fraud and integrity decisions remain explainable and reviewable by humans.
- Tenant configuration drives UI behavior and server-side validation.

Nomination Create Design

Endpoint: **POST /api/nominations**

Input:

- **BeneficiaryId**
- **Amount**
- **NominationDescription**
- Optional **CategoryId**

Processing:

1. Resolve effective user from auth context.
2. Read **TenantId**.
3. Validate beneficiary exists in tenant.
4. Resolve beneficiary manager as approver.
5. Read tenant config for currency, min award, and max award.
6. Validate amount.
7. If tenant categories exist, require and validate **CategoryId**.
8. Read description check config.
9. Run synchronous description structure checks:
 - Word count or character count.
 - Boilerplate phrase checks.
10. Save nomination as **Submitted**.
11. Audit impersonated action if applicable.
12. Publish **nomination.submitted**.
13. Return **{ Status: "Submitted", Message: "Nomination submitted successfully" }**.

Important design note: fraud detection does not run inside the HTTP request. The submission endpoint saves a durable nomination and emits an event so the worker can run heavier semantic and ML processing asynchronously.

Integrity Check Design

Worker: **integrity-check**

Input event: **nomination.submitted**

Processing:

1. Receive message from `fraud-processor`.
2. Decode JSON body.
3. Extract trace context.
4. Claim `ProcessedEvents` row by message ID.
5. Load nomination details.
6. Run description checks:
 - Category alignment.
 - Duplicate description.
 - Optional LLM semantic review.
7. If description is rejected:
 - Set nomination status to `Rejected`.
 - Publish `nomination.description-rejected`.
8. Run P2P fraud assessment:
 - Load tenant model from Blob Storage if available.
 - Build feature vector from nomination, history, semantic similarity, graph flags, and tenant stats.
 - Predict fraud probability.
 - Convert to score and risk level.
 - Generate warning flags.
 - Optionally compute SHAP explanations and LLM-readable explanation.
 - Save fraud flags and scores.
9. Route:
 - Clean: set status `Pending`, publish `nomination.created`.
 - Flagged: set status `PendingHRBPReview`, publish `nomination.fraud-flagged`.
10. Complete message on success.

HRBP Review Design

Endpoints:

- `GET /api/hrbp/queue`
- `POST /api/hrbp/nominations/{nomination_id}/approve`
- `POST /api/hrbp/nominations/{nomination_id}/reject`
- `GET /api/hrbp/nominations/{nomination_id}/pair-history`

Authorization:

- Effective user must have `HRBP` in `UserRoles`.

Approve behavior:

- Requires nomination status `PendingHRBPReview`.
- Enforces same tenant.
- Sets status to `Pending`.
- Writes non-fraud label through `upsert_p2p_fraud_label`.
- Publishes `nomination.hrbp-approved`.
- Publishes `nomination.created` so manager approval continues.

Reject behavior:

- Requires nomination status **PendingHRBPReview**.
- Enforces same tenant.
- Sets status to **Rejected** with reason and actor **HRBP Review**.
- Writes fraud label through **upsert_p2p_fraud_label**.
- Publishes **nomination.hrbp-rejected**.

Manager Approval Design

Endpoint: **POST /api/nominations/approve**

Input:

- **NominationId**
- **Approved**
- **reason**

Processing:

1. Resolve effective user and tenant.
2. Load nomination approver scoped by tenant.
3. Reject if not found.
4. Reject if effective user is not the assigned approver.
5. If approved:
 - Set nomination to **Approved**.
 - Warm certificate cache when tenant config requires attachment.
 - Publish **nomination.approved**.
 - Audit impersonated action if applicable.
6. If rejected:
 - Set nomination to **Rejected**.
 - Store reason and actor **Manager**.
 - Publish **nomination.approved** for downstream outcome handling.
 - Audit impersonated action if applicable.

Design note: **nomination.approved** is used as an outcome event even when the decision is rejection. Downstream handlers inspect current status/details.

Email Action Link Design

Endpoints:

- **GET /api/nominations/email-action**
- **POST /api/nominations/email-action**

The approve/reject links use signed action tokens.

GET behavior:

- Verifies token.
- Checks nomination and expected approver.
- Approve action approves immediately.
- Reject action shows a reason form.

POST behavior:

- Verifies token.
- Requires reject action.
- Captures reason.
- Rejects nomination and publishes outcome event.

Auxiliary Worker Design

Worker: **auxiliary-service**

Input subscription: **email-processor**

Dispatcher handlers:

Event	Handler behavior
nomination.created	Email manager approval request.
nomination.approved	Email nominator outcome and submit payout.
payout.accepted	Mark payout accepted/payment status.
payroll.accepted	Mark nomination paid.
payroll.failed	Notify support users.
notification.requested	Send free-form notification from analytics agent.
notification.access_requested	Send demo access invitation.
nomination.description-rejected	Notify nominator of description rejection.
nomination.fraud-flagged	Notify HRBP users.
nomination.hrbp-approved	Notify nominator that HRBP approved review.
nomination.hrbp-rejected	Notify nominator that HRBP rejected.
nomination.hrbp-sla-breach	Alert HRBP reviewers about stale review.

Idempotency:

- Message ID is inserted into **ProcessedEvents** before handler execution.
- Duplicate message IDs are skipped.
- Handler failures update result to **error** and re-raise so the message can be retried.

Payroll Broker Design

Service: **payroll-broker**

Responsibilities:

- HTTP endpoints for provider OAuth and webhooks.
- Employee pay lookup through **/employee-pay**.
- Background worker consuming **nomination.approved**.
- Provider registry for Gusto, Rippling, and future providers.
- Token encryption for provider OAuth credentials.
- Payroll result events back to Service Bus.

Flow:

1. Consume `nomination.approved` from `payroll-processor`.
2. Resolve tenant payroll provider.
3. Resolve nomination and employee data.
4. Submit off-cycle or bonus payroll through provider implementation.
5. Upsert `payroll_submissions`.
6. Publish `payroll.accepted` or `payroll.failed`.

Analytics Design

Admin analytics endpoints require `AWard_Nomination_Admin`.

Analytics groups:

- Overview.
- Spending trends.
- Department spending.
- Top recipients.
- Top nominators.
- Fraud alerts.
- Approval metrics.
- Diversity metrics.
- Category breakdown.
- Forecast.
- Integrity runs and findings.
- Conversation history.
- Ask and investigate AI workflows.

AI ask:

- Stores conversations and messages in SQL.
- Uses the AskAgent for tenant-scoped analytics.
- Supports export payloads.

AI investigate:

- Uses AgentsOrchestrator.
- Coordinates fraud analysis, exports, and notification skills.

Internal Endpoint Design

Internal callbacks use shared secrets through `X-Internal-Key`.

Known internal flows:

- Fraud analytics job calls `/api/internal/refresh-fraud-model` after model upload.
- HRBP SLA Logic App calls `/api/internal/checkPendingHRBPReview`.

Configuration Variables

Important environment variables include:

- `CLIENT_ID`
- `CORS_ALLOWED_ORIGINS`
- `APPLICATIONINSIGHTS_CONNECTION_STRING`
- `SQL_SERVER`, `SQL_DATABASE`, `SQL_USER`, `SQL_PASSWORD`
- `SERVICE_BUS_FQNS`, `SERVICE_BUS_TOPIC_NAME`, `SERVICE_BUS_SUBSCRIPTION_NAME`
- `AZURE_STORAGE_ACCOUNT`
- `MODEL_CONTAINER`
- `MODEL_IDLE_TTL_SECONDS`
- `MODEL_EVICTION_INTERVAL_SECONDS`
- `AZURE_OPENAI_ENDPOINT`, `AZURE_OPENAI_KEY`, `AZURE_OPENAI_DEPLOYMENT`
- `PAYROLL_BROKER_BASE_URL`
- `FRAUD_ANALYTICS_JOB_WEBHOOK_SECRET`
- `HRBP_SLA_WEBHOOK_SECRET`

Error Handling Design

- FastAPI validation errors are flattened into `{ "detail": "<message>" }`.
- Auth failures use 401, 403, or 404 depending on cause.
- Business rule failures return 400 or 422.
- Worker invalid JSON is dead-lettered.
- Worker transient handler failure abandons the message for retry.
- Unknown auxiliary event types are skipped silently with warning.
- Payroll broker errors are mapped to 503, 502, or 404 as appropriate.